ПР2. Проектирование защищённой инфраструктуры

Условная образовательная организация «Школа цифровых практик»

Индивидуальный вариант № 8: электронный журнал

Джамалова Сабина Шахиновна, группа МПИНФ-261м

Цель: спроектировать защищённую цифровую инфраструктуру образовательного учреждения: применить сетевую сегментацию, ролевое управление доступом, многофакторную аутентификацию, управление жизненным циклом учётных записей и резервное восстановление. Все данные в работе синтетические. Логика решений: ситуация -> возможная проблема -> последствие для школы -> защитная мера -> почему она подходит.

1. Четыре риска исходной сети

В исходной сети административные и педагогические компьютеры, ПК обучающихся и серверы находятся в одном контуре и могут обращаться друг к другу без ограничений.

№	Проблема	Возможное событие	Что пострадает
1	ПК обучающегося и серверы в одном контуре	ПК в компьютерном классе заражён вредоносной программой с флешки и обращается к базе отчётности и файловому серверу	персональные данные обучающихся и родителей, соблюдение требований к защите ПДн, доверие родителей
2	Гостевой Wi-Fi не отделён от внутренней сети	гость на родительском собрании или мероприятии видит общие папки и файловый сервер и копирует документы	рабочие материалы педагогов и сведения об обучающихся
3	NAS с резервными копиями доступен с пользовательских ПК	педагог открывает вложение с шифровальщиком, шифруются файлы на сервере и сами резервные копии	работы и оценки, непрерывность занятий; восстановить данные не из чего
4	Публичный сайт стоит в общей сети с внутренними сервисами	сайт взломан, злоумышленник из него переходит к административному интерфейсу и базе отчётности	служебные данные, достоверность информации на сайте, репутация школы

2. Защищённая архитектура

Сеть разделена на шесть сегментов: административный, педагогический, обучающихся, гостевой, серверный и публичный (DMZ). Седьмая зона, Интернет, содержит облачные LMS и электронный журнал. Сегменты напрямую не связаны: весь обмен идёт через межсетевой экран, где применяются правила раздела 3.

Электронный журнал находится в облаке и открывается только из административного и педагогического сегментов с MFA (см. вариант в разделе 9).

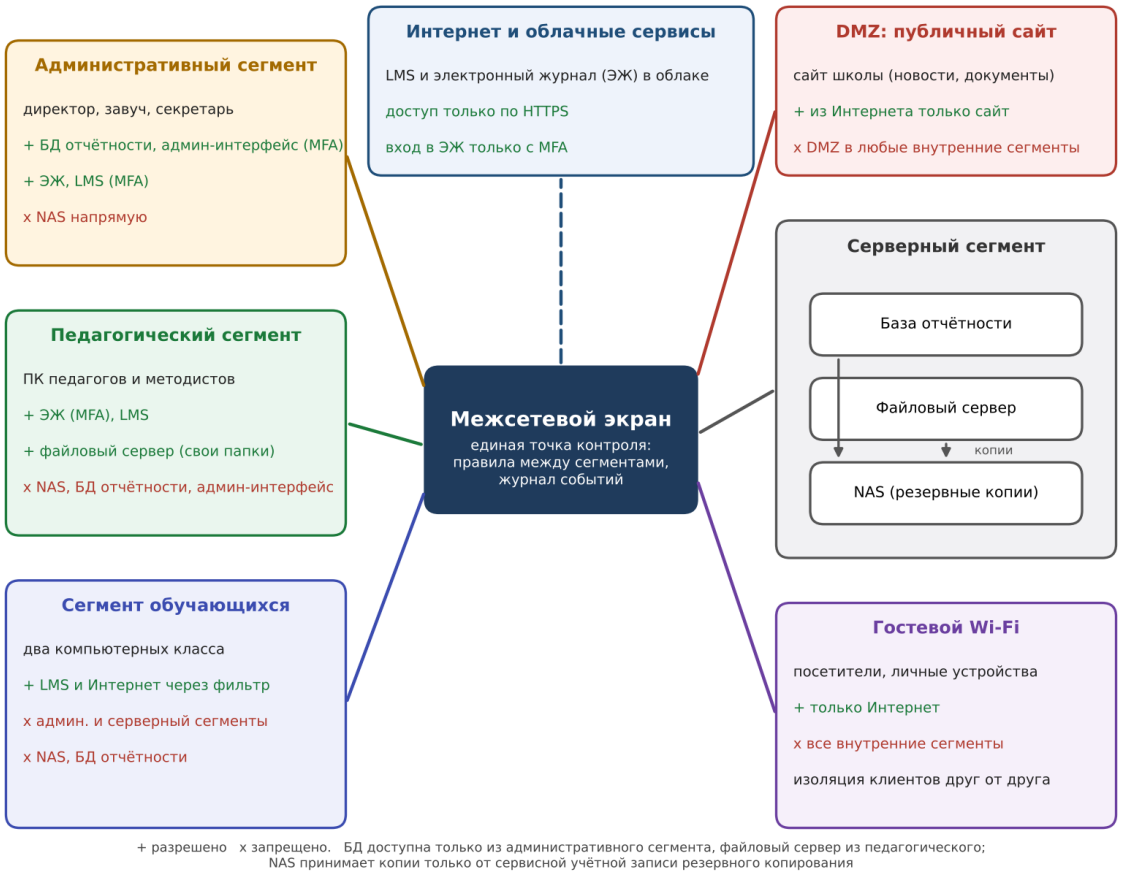


Рисунок 1. Архитектура после сегментации: межсетевой экран как точка контроля, разрешённые (+) и запрещённые (x) взаимодействия.

3. Шесть сетевых правил

Источник	Назначение	Сервис / назначение	Решение	Обоснование
Гостевой сегмент	Интернет	веб-доступ (HTTP/HTTPS, DNS)	разрешить	гостям и родителям нужен только Интернет
Гостевой сегмент	все внутренние сегменты	любые сервисы	запретить	гостевые устройства не контролируются школой; изоляция клиентов защищает и самих гостей
Обучающиеся	LMS, Интернет	HTTPS через контент-фильтр	разрешить	нужно для занятий; фильтрация вредной информации обязательна для детей

Источник	Назначение	Сервис / назначение	Решение	Обоснование
Обучающиеся	административный и серверный сегменты, NAS	любые сервисы	запретить	заражённый ученический ПК не должен дотянуться до служебных данных и копий
Педагоги	электронный журнал, LMS, файловый сервер	HTTPS; доступ к своим папкам	разрешить	ежедневная работа педагога; NAS, база отчётности и админ-интерфейс остаются закрытыми
Администрация	серверный сегмент (база отчётности, админ-интерфейс)	административный доступ	разрешить с MFA	привилегированный доступ защищён вторым фактором; только из административного сегмента

Дополнительно действуют два правила: из DMZ нет соединений во внутренние сегменты, а на NAS записывает копии только сервисная учётная запись резервного копирования.

4. RBAC

Обозначения: R чтение; RW чтение и изменение; A администрирование; - нет доступа; * только собственные объекты (обучающийся свои работы и оценки, педагог свои классы и предметы).

Роль	**LMS**	**Электронный журнал**	**Файловое облако**	**База отчётности**	**Резервные копии**
Обучающийся	RW*	R*	RW*	-	-
Педагог	RW	RW*	RW	R*	-
Методист	RW	R	RW	R	-
Руководитель	R	R	R	R	-
Системный администратор	A	A	A	A	A

Два неочевидных решения. Первое: методист видит журнал только на чтение (R), хотя работает с учебными материалами и отчётностью. Ему нужна картина по школе, но право менять оценки у него убрало бы ответственность педагога за выставленный результат. Второе: роль «Системный администратор» (A) в журнале означает техническое сопровождение, а не право выставлять или

править оценки; резервные копии доступны только ей, иначе шифровальщик, запущенный под учётной записью педагога, уничтожил бы и их.

5. Сервисные аккаунты

Аккаунт	***Лишние права***	**Минимально необходимые права**	**Интерактивный вход человека**
svc_backup	права администратора сервера	чтение источников копирования (база отчётности, файловый сервер) и запись в хранилище NAS без права удалять и менять прежние копии	нет
svc_lms_report	изменение пользователей	чтение данных LMS, нужных для отчётов	нет
svc_site_sync	доступ к базе данных, чтение всего файлового сервера	чтение одной папки с подготовленными материалами и запись в каталог публикации сайта	нет

6. Жизненный цикл учётных записей и MFA

1. **Где MFA обязательна.** Для администраторов, руководителя, методистов и педагогов при входе в электронный журнал, а также для любого удалённого доступа к внутренним ресурсам. Проверка: раз в месяц администратор выгружает из журнала список учётных записей, и ни у одной записи этих ролей второй фактор не отключён.

2. **Создание учётной записи.** Только по письменной заявке руководителя или завуча с указанием должности; роль назначается по шаблону должности, а не вручную по правам. Второй фактор настраивается до первого входа в журнал, временный пароль меняется при первом входе. Срок: в день начала работы.

3. **Смена должности или роли.** Права прежней роли снимаются в день приказа, права новой роли выдаются отдельно по шаблону. В течение трёх рабочих дней администратор и завуч сверяют фактические права с приказом и подписывают лист проверки.

4. **Увольнение и отчисление.** Блокировка всех учётных записей и завершение сессий (журнал, LMS, облако, почта) не позднее дня прекращения полномочий, по приказу, а не по отдельной заявке. Ответственный за ПДн проверяет блокировку и подписывает акт в течение одного рабочего дня.

5. **Восстановление доступа.** Сброс пароля или второго фактора только после личной идентификации в школе по документу, не по телефону и не через чат.

Повышение роли и право изменять оценки подтверждает письменно руководитель, администратор не меняет роль по просьбе самого пользователя; каждое такое изменение фиксируется в журнале.

7. RPO и RTO

Сервис	RPO	RTO	Краткое обоснование
LMS	4 часа	4 часа	важны непрерывность занятий и сохранность работ обучающихся; в период аттестации значения ужесточаются до 1 часа
Электронный журнал	1 час	8 часов	потеря или искажение оценок хуже кратковременной недоступности: отметки можно внести позже в тот же день, а неверные оценки исправлять трудно
Публичный сайт	24 часа	24 часа	не влияет на ход занятий, содержимое восстанавливается из исходных материалов

8. Контрольное восстановление

8.1. Проверка в Google Colab (вариант 8)

Из файла grades_all_variants.csv выбран вариант 8 и создан файл grades.csv с 10 условными записями (коды U01-U10) и строкой заголовка. Затем выполнены резервное копирование и восстановление, после чего сравнены SHA-256 и число строк.

```
import shutil
shutil.copyfile("grades.csv", "backup_grades.csv")
shutil.copyfile("backup_grades.csv", "restored_grades.csv")

import hashlib
def sha256_file(path):
    with open(path, "rb") as f:
        return hashlib.sha256(f.read()).hexdigest()
def line_count(path):
    with open(path, "r", encoding="utf-8-sig") as f:
        return sum(1 for _ in f)
source_sha = sha256_file("grades.csv")
restored_sha = sha256_file("restored_grades.csv")
source_lines = line_count("grades.csv")
```

```
restored_lines = line_count("restored_grades.csv")
```

Результат:

```
SHA-256 исходного файла:
c699c6cf2a919038cc00c274e3e85c5bf2d77e8bf8a39a1a1ba0a68b8b572d3a

SHA-256 восстановленного файла:
c699c6cf2a919038cc00c274e3e85c5bf2d77e8bf8a39a1a1ba0a68b8b572d3a

Число строк: 11 и 11
```

Проверка	grades.csv	restored_grades.csv
SHA-256	c699c6cf2a919038cc00c274e3e85c5bf2d77e8bf8a39a1a1ba0a68b8b572d3a	c699c6cf2a919038cc00c274e3e85c5bf2d77e8bf8a39a1a1ba0a68b8b572d3a
Число строк	11 (заголовок + 10 записей)	11 (заголовок + 10 записей)
Итог	совпадает	совпадает

8.2. Проверка в PowerShell (restore_dataset.csv)

Создан файл restore_dataset.csv с набором из задания (10 синтетических записей), зафиксированы размер, число строк и SHA-256, файл скопирован как restore_dataset_recovered.csv и проверен повторно.

```
$t = "id,class_code,status`nS001,5A,active`nS002,5A,active`nS003,6B,active`nS004,7A,active`nS005,7A,active`nS006,8B,active`nS007,9A,active`nS008,9A,active`nS009,10B,active`nS010,11A,active`n"
[System.IO.File]::WriteAllText("$PWD\restore_dataset.csv", $t, (New-Object System.Text.UTF8Encoding $false))
```

Проверка исходного файла:

```
(Get-Item .\restore_dataset.csv).Length
(Get-Content .\restore_dataset.csv).Count
Get-FileHash .\restore_dataset.csv -Algorithm SHA256
```

Копирование (восстановление) и повторная проверка:

```
Copy-Item .\restore_dataset.csv .\restore_dataset_recovered.csv
(Get-Item .\restore_dataset_recovered.csv).Length
(Get-Content .\restore_dataset_recovered.csv).Count
```

```
Get-FileHash .\restore_dataset_recovered.csv -Algorithm SHA256
```

Проверка	restore_dataset.csv	restore_dataset_recovered.csv
Размер, байт	173	173
Число строк	11 (заголовок + 10 записей)	11 (заголовок + 10 записей)
SHA-256	22adb82f8fa5391cea7fcb493569041a0746235996d1ab58c6813673ccf517fc	22adb82f8fa5391cea7fcb493569041a0746235996d1ab58c6813673ccf517fc
Итог	совпадает	совпадает

Вывод. В обеих проверках размер, число строк и SHA-256 исходных и восстановленных файлов совпали, следовательно, восстановленные копии идентичны исходным, а резервное копирование и восстановление работают.

9. Индивидуальный вариант № 8

Задание 1. Риск нарушения целостности оценок

Источник	Уязвимость	Событие	Последствие для школы
злоумышленник с украденным паролем педагога или недобросовестный пользователь; ошибка при массовом редактировании	MFA для педагогов не обязательна; права на правку оценок шире необходимых; изменения не фиксируются в журнале событий	оценки в журнале изменены в чужом классе или после закрытия периода, и никто не может определить, кто и когда это сделал	неверные итоговые оценки, жалобы родителей и споры, невозможность доказать, какая запись верная, пересчёт результатов аттестации

Оценка. До мер P = 3, I = 4, R = 12 (высокий риск); после мер P = 2, I = 3, R = 6 (умеренный). **Меры по причине риска.** MFA для всех, кто может менять оценки, закрывает вход по краденому паролю (снижает P); права на правку только у педагога и только в его классах и предметах, правка закрытого периода только по заявке с подтверждением руководителя (снижает P); журнал изменений с указанием автора, времени и прежнего значения и возможность откатить правку из копии (снижает I).

Задание 2. Кто может изменять оценки (RBAC)

Роль	Право изменять оценки	Условия
Педагог	да	только свои классы и предметы, текущие оценки открытого периода; каждое изменение фиксируется

Роль	Право изменять оценки	Условия
Методист	нет (R)	только просмотр для отчётности и методической работы
Руководитель	нет (R)	просмотр и контроль; утверждает правку оценок закрытого периода по заявке педагога
Системный администратор	нет (A)	только техническое сопровождение; восстановление из копии по письменному распоряжению руководителя с записью в журнале
Обучающийся	нет (R*)	видит только свои оценки

Задание 3. Для каких ролей MFA обязательна при работе с журналом

Роль	MFA	Почему
Педагог	обязательна при каждом входе с нового устройства и при входе вне школы	единственная роль, которая меняет оценки; кража пароля даёт возможность править результаты класса
Методист и руководитель	обязательна	доступ к данным всей школы, включая ПДн; учётная запись руководителя утверждает критичные правки
Системный администратор	обязательна всегда	привилегированная роль, управляет всей системой и копиями
Обучающийся	не требуется	только чтение собственных оценок; достаточно личной учётной записи и надёжного пароля

10. Педагогический комментарий

Мера: обязательная MFA для педагогов при работе с электронным журналом. Неудобство в том, что перед уроком нужно подтвердить вход вторым фактором, а если телефон забыт, разряжен или нет сети, отметка посещаемости задерживается. Отменить меру нельзя: пароль педагога может быть украден фишингом, и тогда оценки класса можно изменить, а персональные данные увидеть. Чтобы сохранить доступность, второй фактор настраивается заранее, до начала четверти, педагоги получают резервные коды, на школьном ПК доступна функция «запомнить устройство» на ограниченный срок, а дежурный администратор в течение десяти минут выдаёт одноразовый код; отметки при сбое вносятся позже в тот же день.

11. Вывод

Плоская сеть даёт заражённому ученическому или гостевому устройству прямой путь к данным и резервным копиям. Разделение на шесть сегментов с межсетевым экраном, шесть правил между ними, ролевая модель с минимальными правами и понятный порядок работы с учётными записями снижают этот риск, не мешая занятиям. По варианту 8 главным риском для журнала стала подмена оценок: её закрывают MFA, право правки только у педагога и журнал изменений. Контрольное восстановление подтвердило, что копии совпадают с исходными файлами, а значения RPO и RTO учитывают, что для журнала целостность оценок важнее скорости восстановления.